Bibliothèque de cas CyberRiskGuardian

Cinq études de cas fictives pour l'enseignement — Ensemble pédagogique 1.0

Marc-André Léger, Ph. D.

octobre 2026

1 À propos des cas

Les cinq cas de cette bibliothèque sont des organisations fictives rédigées pour des cours de cybersécurité, d'audit, de gouvernance, de protection des renseignements personnels et de gestion des risques. Ils partagent une même structure (version 2.0c), de sorte que les étudiants qui apprennent la méthode avec un cas peuvent l'appliquer à un autre :

- **Module A — Réponse aux incidents :** un incident réel ou simulé et les décisions qu'il exige.
- **Module B — Planification de l'audit :** un univers d'audit et un plan d'audit fondé sur les risques.
- **Module C — Gestion des risques :** l'appétence pour le risque, une bibliothèque de scénarios de risque et un registre des risques.
- **Options de travaux 1 à 3 :** exercice de simulation d'incident sur table, plan d'audit, évaluation des risques avec une feuille de route pluriannuelle.

Les versions étudiantes dans `cases/` contiennent le récit, les annexes de preuves et la bibliothèque de scénarios. Les annexes de l'enseignant (scénarios détaillés avec des valeurs de paramètres illustratives, exemples de réponses, plans de diffusion progressive et notes d'étalonnage) se trouvent dans l'Édition Éducateur.

Les cas sont fictifs. Ils sont réalistes, mais ne décrivent aucune organisation, aucun organisme de réglementation, fournisseur, employé, client ou incident réels. Les chiffres sont des hypothèses pédagogiques.

2 Choisir un cas

Cas	Secteur	Taille	Tolérance au cyberrisque énoncée	Bibliothèque de scénarios	Difficulté	Idéal pour
Chez Pierre	Restauration (établissements corporatifs et franchisés)	30 restaurants ; équipe TI d'environ 32 personnes ; budget de cybersécurité de 1,3 M$ CA	0,4	9 pistes de scénarios	Introduction	Première évaluation des risques ; cours de technologie d'affaires ; discussion stratégique

Cas	Secteur	Taille	Tolérance au cyberrisque énoncée	Bibliothèque de scénarios	Difficulté	Idéal pour
MediBec	Soins de santé privés	Siège social et 10 cliniques ; 15 employés TI, dont 2 en cybersécurité ; budget TI de 100 M$ CA	0,40 (revue par la haute direction au-dessus de 0,25, conseil d'administration au-dessus de 0,40)	15 scénarios	Intermédiaire	**Le cas des laboratoires** (exemple résolu complet publié) ; protection des renseignements de santé ; arbitrages liés à la sécurité des patients
CanaRetail	Commerce de détail national	100 magasins et commerce électronique ; environ 62 employés TI ; budget TI de 150 M$ CA (2026)	0,5 (neutre face au risque)	50 pistes + 9 scénarios fournis	Intermédiaire	Le travail noté A1 avec le modèle Excel de CRG (le module D est conçu pour lui) ; sécurité des paiements ; budgétisation
ACRB	Banque régionale	30 succursales ; environ 750 employés, dont 83 en TI ; brèche en 2022	0,30 (revue par la haute direction au-dessus de 0,20, conseil d'administration au-dessus de 0,30)	15 scénarios	Avancé	Audit des TI avec constatations antérieures ; secteur réglementé ; reddition de comptes au conseil d'administration ; rétablissement après incident
CNIC	Assureur national	Plus de 3 millions de clients ; budget TI de 315 M$ CA, dont 50 M$ en cybersécurité	0,34 (revue par la haute direction au-dessus de 0,20, conseil d'administration au-dessus de 0,34)	12 scénarios	Avancé	Grande entreprise ; gouvernance de l'IA (plateforme de réclamations fondée sur l'IA) ; projets intégrateurs et séminaires des cycles supérieurs

Approche recommandée. Utilisez **MediBec** pour les laboratoires (les étudiants peuvent se comparer à l'exemple résolu publié) et attribuez un cas **différent** pour les travaux notés. Faites alterner les cas d'une session et d'un groupe-cours à l'autre. Un sixième cas, réservé à l'examen final, se trouve dans l'Édition Éducateur.

3 Utiliser un cas avec CyberRiskGuardian

1. **Créez un espace de travail pour le cas.** Application de bureau : Organisation → Espaces de travail → *Nouvel espace de travail*, type *Cas d'affaires pour la classe*, cochez *Cas pédagogique utilisé à des fins de formation*, déposez le document du cas et extrayez le profil et les joyaux de la couronne (actifs critiques). Claude : joignez le document du cas et exécutez `/crg-assess` ou `/crg-quick-scan`.
2. **Utilisez la tolérance au risque du cas comme appétence pour le risque de départ.** Les étudiants peuvent proposer une valeur différente, mais doivent la justifier (laboratoire 2).

3. **Traitez la bibliothèque de scénarios comme des candidats, et non comme des réponses.** Les entrées de la bibliothèque sont de courts thèmes. Les étudiants doivent réécrire chacune de celles qu'ils retiennent sous la forme d'une chaîne causale complète ancrée dans le cas.
4. **Transposez le modèle de cotation du cas dans celui de CRG.** La plupart des cas décrivent un modèle normalisé simple (menace × exposition × impact, ajusté selon la maturité des contrôles) assorti de seuils de remontée. CRG utilise six paramètres et un ratio de tolérance. Les deux grilles de lecture peuvent diverger ; les étudiants devraient préciser à laquelle un seuil de gouvernance fait référence.
5. **Utilisez la définition de μ(E) de CRG.** Dans CyberRiskGuardian, μ(E) est la *criticité organisationnelle* du service ou du processus touché. Certains textes de cas emploient l'étiquette « utilité espérée » dans d'autres sens (par exemple pour des mesures d'atténuation, ou comme produit d'autres facteurs). Pour le travail avec CRG, estimez toujours μ(E) en tant que criticité.
6. **Vérifiez chaque score CVSS par rapport à son vecteur.** Calculez les scores avec un calculateur ; ne copiez jamais un score sans son vecteur.

Version 2.0c. Les cas de cet ensemble sont à la version 2.0c : μ(E) y est désigné comme *criticité organisationnelle* partout, conformément à CyberRiskGuardian, et les scores CVSS du matériel destiné à l'enseignant ont été recalculés à partir de leurs vecteurs.

4 Les cas

4.1 Chez Pierre — restauration gastronomique (introduction)

Organisation. Un groupe de restaurants montréalais fondé en 2005, comptant 10 restaurants corporatifs (Montréal, Mont-Tremblant, Québec, Ottawa, Toronto, Mississauga, Edmonton, Banff, Vancouver, Whistler) et 20 restaurants franchisés.

Ce qui compte. Les points de vente et le traitement des paiements, les réservations en ligne, les commandes en ligne (application, site Web, plateforme de livraison), la gestion centralisée des données (recettes, contrats fournisseurs, dossiers des employés et dossiers financiers), le CRM et la fidélisation, l'intégration des stocks et des fournisseurs, le Wi-Fi des clients et l'équipement de cuisine connecté.

Contexte de risque. Tolérance en matière de cybersécurité de 0,4, décrite comme modérément réfractaire au risque ; faible appétence pour les risques de cybersécurité, de protection des renseignements personnels, opérationnels, de conformité et de réputation. Postes du budget TI 2024 : exploitation 5,6 M$ CA, développement 3,0 M, salaires 6,4 M$. La sécurité des cartes de paiement (PCI DSS) et les exigences canadiennes en matière de protection des renseignements personnels sont mentionnées.

Pistes de scénarios (9). Hameçonnage visant la messagerie de l'entreprise · rançongiciel sur le système de réservation · logiciel malveillant sur les points de vente · fuite par un initié · DDoS sur les commandes en ligne aux heures de pointe · attaque de l'intercepteur sur le Wi-Fi des restaurants · mots de passe administratifs faibles · ingénierie sociale visant à obtenir des identifiants · vulnérabilité du jour zéro dans un logiciel non corrigé.

Angles pédagogiques. Le modèle de franchise (qui contrôle la technologie locale ?), un petit budget de cybersécurité, les questions de stratégie d'affaires qui entourent l'analyse des risques. Un bon premier cas : un contexte d'affaires simple, peu de scénarios, une seule valeur de tolérance. L'option d'évaluation des risques exige au moins six scénarios.

4.2 MediBec — soins de santé privés (intermédiaire ; cas des laboratoires)

Organisation. Un centre médical privé doté d'un siège social à Montréal et de 10 cliniques dans les régions de Montréal, de Québec, de Gatineau et du Saguenay.

Ce qui compte. Le dossier de santé électronique ; les systèmes de radiologie, de laboratoire et de pharmacie ; la facturation ; la prise de rendez-vous et les services en ligne aux patients ; l'identité et l'accès à distance ; le centre de données de Montréal, le réseau étendu et les sauvegardes ; l'équipement médical connecté ; les communications des cliniciens.

Contexte de risque. Faible appétence pour le risque en matière de sécurité des patients, de confidentialité des données de santé, de conformité et de confiance du public ; tolérance normalisée de 0,40 ; un risque résiduel supérieur à 0,25 exige une revue par la haute direction, et supérieur à 0,40, l'acceptation du conseil d'administration ou du groupe propriétaire. Un service TI restreint de 15 personnes, dont deux en cybersécurité ; budget TI de 100 M$ CA ; feuille de route 2024–2030. Plusieurs attaques infructueuses depuis 2020, en hausse récemment ; aucune brèche confirmée.

Bibliothèque de scénarios (15). MED-CYR-01 à MED-CYR-15 : compromission d'identifiants, rançongiciel sur le DSE, mauvaise configuration infonuagique, exposition de clés d'API, compromission du réseau sans fil d'une clinique, application tardive des correctifs, serveurs de sauvegarde exposés, détection d'intrusion inadéquate, point d'ancrage par un dispositif médical ou un objet connecté, DDoS sur les services aux patients, exfiltration par un initié, hameçonnage du personnel, attaque contre l'intégrité des données des dossiers des patients ou de facturation, compromission d'un fournisseur, réponse aux incidents non testée.

Angles pédagogiques. Des décisions de confinement aux conséquences cliniques ; la question de savoir si la tolérance devrait différer entre les systèmes administratifs et les systèmes de soins ; la priorisation avec une équipe de deux personnes. L'évaluation CRG publiée (30 scénarios ; risque estimé de 84 305 et risque résiduel de 41 023) et la trousse de simulation MediBec de l'application de bureau (trois semaines d'activité du SOC) en font le cas tout désigné pour les laboratoires.

4.3 CanaRetail — commerce de détail national (intermédiaire)

Organisation. Un détaillant dont le siège social est à Montréal (magasins exploités sous la bannière Maison Helenas), comptant 100 magasins au Canada et une plateforme nationale de commerce électronique.

Ce qui compte. Le commerce électronique et les passerelles de paiement, les terminaux de point de vente de 100 magasins, le PGI SAP S/4HANA, les données de fidélisation et de CRM, les données des titulaires de cartes, les stocks, le centre de données de Montréal, les sauvegardes et les sites de relève ; AWS et Azure ; les objets connectés en magasin (tablettes intelligentes, caméras, étiquettes NFC).

Contexte de risque. Appétence pour le risque globalement modérée, « neutre face au risque (0,5) », avec une faible appétence pour les brèches de données et l'atteinte à la réputation, et une très faible appétence pour les risques réglementaires, de protection des renseignements personnels et de conformité des paiements ; les interruptions des ventes en ligne ne devraient pas dépasser 24 heures. Budget TI 2026 de 150 M$ CA, salaires compris ; enveloppe de cybersécurité passant de 6,2 M$ CA (2023) à 26,57 M$ CA (2031) selon la projection du cas. Les étudiants sont invités à remettre en question l'énoncé d'appétence pour le risque.

Pistes de scénarios (50). Cinquante courts thèmes, de l'hameçonnage visant les dirigeants, du rançongiciel et des logiciels malveillants sur les points de vente jusqu'aux réseaux de zombies d'objets connectés, aux faiblesses des API, à l'informatique fantôme et à l'écoute clandestine des téléconférences. Le **module D** demande aux équipes

de combiner un scénario de risque original avec **neuf scénarios fournis** dans le modèle Excel de CRG ; l'enseignant distribue ces neuf scénarios sous forme de document (fourni dans l'Édition Éducateur).

Angles pédagogiques. Conçu pour le travail A1 avec le classeur CRG ; sécurité des paiements ; budgétisation par rapport à la cible cohérente avec l'appétence (7,8 % du budget TI à l'appétence de 0,5 du cas) ; une formulation délicate concernant le ciblage fondé sur l'identité, que les enseignants voudront peut-être présenter en classe.

4.4 ACRB — Atlantic Canada Regional Bank (avancé)

Organisation. Une banque communautaire sous réglementation fédérale dont le siège social est à Halifax, fondée en 1952, comptant 30 succursales, environ 750 employés (dont 83 en TI), environ 800 guichets automatiques et 700 terminaux de point de vente.

Ce qui compte. Un système bancaire central propriétaire datant des années 1970, les services bancaires en ligne et mobiles, les réseaux de guichets automatiques et de points de vente, les données des clients (y compris les numéros d'assurance sociale), le centre de données de Halifax et le site de relève de Moncton, les services d'identité, la connectivité des succursales.

Contexte de risque. En 2022, une campagne de harponnage a mené à deux semaines de présence non détectée, à un rançongiciel et à l'exfiltration présumée de données concernant plus de 100 000 clients, à environ une semaine de perturbation et à 2 M$ CA de dommages immédiats ; la direction a été renouvelée et un poste de chef de la sécurité de l'information (CISO) a été créé. Tolérance normalisée de 0,30 ; un risque résiduel supérieur à 0,20 exige une revue par la haute direction, et supérieur à 0,30, l'acceptation du conseil d'administration. Constatations antérieures de l'audit interne (inventaire des actifs, signalement de l'hameçonnage, vulnérabilités des systèmes patrimoniaux, aucun exercice sur table portant sur un rançongiciel, tests de restauration limités). La ligne directrice B-13 du BSIF, les exigences de déclaration des incidents du BSIF et les lignes directrices de la LPRPDE sur les atteintes à la vie privée sont mentionnées.

Bibliothèque de scénarios (15). CYR-01 à CYR-15 : du harponnage au rançongiciel, compromission d'un compte privilégié, exploitation du système bancaire central patrimonial, mauvaise configuration infonuagique, compromission d'un sous-traitant de traitement des paiements, faiblesse de l'API mobile, initié sur le départ, saturation des alertes au SOC, compromission des sauvegardes, logiciel malveillant sur les guichets automatiques et points de vente, DDoS pendant un incident public, appareils personnels non gérés, défaillance du cycle de vie des certificats, intrusion physique au centre de données, abus de l'accès à distance d'un fournisseur.

Angles pédagogiques. Planification de l'audit à partir de véritables constatations antérieures ; délais de déclaration réglementaires ; reddition de comptes au conseil d'administration après une crise ; indépendance du CISO. Idéal pour les cours d'audit et les étudiants avancés.

4.5 CNIC — Canadian National Insurance Company (avancé)

Organisation. Un assureur national fondé en 1968, dont le siège social est à Montréal, comptant plus de 3 millions de clients et des bureaux à Toronto, Vancouver, Montréal, Calgary et Halifax ; centres de données à Montréal et à Calgary.

Ce qui compte. Une plateforme de réclamations fondée sur l'IA (réception, triage, détection de la fraude, paiements), un CRM piloté par l'IA, le PGI SAP, le portail client, l'application mobile et la réponse vocale par IA, les données personnelles, médicales, de réclamations et financières, un nuage hybride AWS/Azure, des sous-traitants de traitement des réclamations et des fournisseurs.

Contexte de risque. Tolérance normalisée de 0,34 ; un risque résiduel supérieur à 0,20 exige une revue par la haute direction, et supérieur à 0,34, l'acceptation du conseil d'administration ; un seuil supplémentaire pour le risque lié à l'IA. Budget TI de l'exercice 2025 de 315 M$ CA, dont 50 M$ CA consacrés à la cybersécurité (environ 16 % — un point à discuter au regard de la ligne directrice de 4 % à 12 %). Dans le cas source, le CISO relève du CIO.

Bibliothèque de scénarios (12). CNIC-01 à CNIC-12 : rançongiciel sur les centres de données, brèche chez un fournisseur, exfiltration par un initié, harponnage visant les dirigeants, mauvaise configuration infonuagique, DDoS sur le portail, menace persistante avancée (APT), logiciel malveillant sur des appareils personnels (AVAN), détournement d'objets connectés, politiques de mots de passe faibles, manipulation des réclamations par l'IA ou défaillance de l'intégrité du modèle, fuite à partir de l'analytique ou du CRM.

Angles pédagogiques. Gouvernance de l'IA et risque lié aux modèles ; un budget très important ; la structure hiérarchique du CISO ; moins d'encadrement que les autres cas. Idéal pour les projets intégrateurs, les séminaires des cycles supérieurs et le modèle 4 du Guide de l'enseignant.

5 Utiliser les cas de façon responsable

- **Ne copiez pas les chiffres des exemples.** Les exemples résolus, les valeurs des annexes et les exemples de mémorandums utilisent des chiffres illustratifs. Les étudiants doivent utiliser les faits de leur propre cas et leurs propres estimations.
- **Signalez les incohérences.** Comme les documents des organisations réelles, les cas peuvent contenir des chiffres qui ne concordent pas. Les étudiants qui en relèvent un devraient le signaler et préciser quel chiffre ils ont utilisé et pourquoi.
- **Qualifiez les faits externes.** Les statistiques ou les obligations légales qui n'apparaissent pas dans le cas doivent être citées à partir d'une source primaire, ou qualifiées d'hypothèses.
- **IA et données fictives.** Les cas sont fictifs et peuvent être utilisés sans risque avec des outils d'IA. Ce n'est pas le cas des documents d'organisations réelles, à moins que l'organisation et l'établissement ne l'autorisent.

© 2026 Marc-André Léger. Cas sous licence CC BY-NC 4.0 pour l'enseignement à des fins non commerciales. Toutes les organisations, personnes et tous les événements sont fictifs.